Theoretical knowledge

1.Understanding security assessment:

Learning to evaluate systems without paid tools.

Explanation:

Security Assessment :

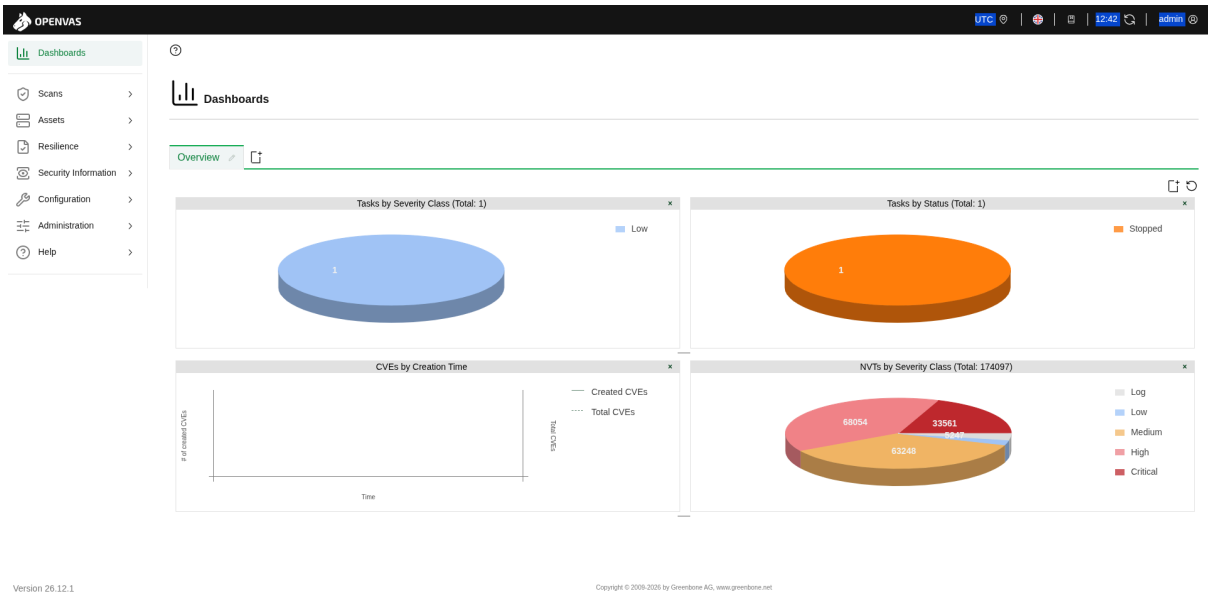
-A structured process of evaluating an organization's security posture by identifying vulnerabilities, misconfigurations, and risks before attackers do.)

- Types of Security Testing:
  - Vulnerability Assessment :

    Identifies and classifies known weaknesses without exploiting them.

    Scan → Detect → Classify → Report → Remediate

    OpenVAS - Network vulnerability scanning - Free



  - Penetration Testing: Simulating attacks with Kali Linux tools (Metasploit, Nmap).

    -Phases of Penetration Testing:

1. RECONNAISSANCE → Gather information about target
2. SCANNING → Identify open ports, services
3. EXPLOITATION → Attempt to exploit vulnerabilities
4. POST-EXPLOITATION→ Assess damage potential
5. REPORTING → Document findings and fixes

2. VAPT Methodology:

VAPT = Vulnerability Assessment + Penetration Testing Vulnerability Assessment → FINDS weaknesses

Penetration Testing → EXPLOITS weaknesses (authorized)

Combined → Complete security picture

PLANNING ⟶ DISCOVERY ⟶ ATTACK ⟶ REPORTING

(Scope) (Recon) (Exploit) (Document)

Phase 1: Planning

- Define scope (what systems are in/out)
- Set rules of engagement
- Gather legal authorization
- Choose methodology - Allocate tools and resources - Set timeline

Phase 2: Discovery:

Network Scanning with Nmap

TYPE	COMMAND FLAG	PURPOSE
SYN Scan	-sS	Stealthy port scan
TCP Connect	-sT	Full TCP connection
UDP Scan	-sU	Discover UDP services
Version Detect	-sV	Identify service versions
OS Detection	-O	Detect operating system
Script Scan	-sC	Run default NSE scripts
Aggressive	-A	All of the above

Nmap Workflow:

STEP 1: Host Discovery
nmap -sn 192.168.1.0/24
→ Finds all live hosts on network

```
┌──(root㉿localhost)-[/home/kali/Downloads]
└─# nmap -sn 192.168.1.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-29 23:39 +0530
Stats: 0:01:01 elapsed; 0 hosts completed (0 up), 256 undergoing Ping Scan
Ping Scan Timing: About 29.79% done; ETC: 23:43 (0:02:24 remaining)
Stats: 0:01:26 elapsed; 0 hosts completed (0 up), 256 undergoing Ping Scan
Ping Scan Timing: About 41.99% done; ETC: 23:43 (0:01:59 remaining)
Stats: 0:01:30 elapsed; 0 hosts completed (0 up), 256 undergoing Ping Scan
Ping Scan Timing: About 43.95% done; ETC: 23:43 (0:01:55 remaining)
Nmap done: 256 IP addresses (0 hosts up) scanned in 205.31 seconds

┌──(root㉿localhost)-[/home/kali/Downloads]
```

STEP 2: Port Scanning
nmap -sS -p 1-65535 <target>
→ Scans all 65535 ports

```
kali@localhost: ~
Session  Actions  Edit  View  Help
┌──(kali㉿localhost)-[~]
└─$ nmap -sS -p 1-65535 192.168.0.136
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-29 23:47 +0530
Nmap scan report for 192.168.0.136
Host is up (0.00014s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
```

STEP 3: Service Detection

nmap -sV -sC <target>

→ Identifies services & versions

```
kali@localhost: ~
Session  Actions  Edit  View  Help
┌──(kali㉿localhost)-[~]
└─$ nmap -sV -sC 192.168.0.136
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-29 23:47 +0530
Stats: 0:00:22 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.34% done; ETC: 23:48 (0:00:00 remaining)
Nmap scan report for 192.168.0.136
Host is up (0.00047s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.0.133
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
```

STEP 4: OS Fingerprinting

nmap -O <target>

→ Detects operating system

```
kali@localhost: ~
Session  Actions  Edit  View  Help
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:18:F6:EF (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.02 seconds

┌──(kali㉿localhost)-[~]
└─$

┌──(kali㉿localhost)-[~]
└─$
```

STEP 5: Save Results

nmap -oX results.xml <target>

→ Export for Dradis/reporting

```
┌──(kali㉿localhost)-[~]
└─$ nmap -oX results.xml 192.168.0.136
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-29 23:53 +0530
Nmap scan report for 192.168.0.136
Host is up (0.00028s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
```

<u>Understanding Nmap Output:</u>

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 7.4
80/tcp	open	http	Apache 2.4.6
443/tcp	open	https	nginx 1.14
3306/tcp	open	mysql	MySQL 5.7.28
8080/tcp	closed	http-alt	

STATE meanings:

open → Service is accessible

closed → Port reachable but no service

filtered → Firewall blocking the port

HIGH → Critical vulnerabilities (SQLi, RCE)
MEDIUM → Significant risks (XSS, CSRF)
LOW → Minor issues (missing headers)
INFO → Informational findings

Phase 3 Attack (Exploitation):

Metasploit Framework

World's most widely used penetration testing framework

Components:

- Exploits → Code that takes advantage of vulnerabilities
- Payloads → Code that runs after successful exploit
- Auxiliaries → Scanners, fuzzers, sniffers
- Post → Post-exploitation modules
- Encoders → Bypass detection

Metasploit Basic Workflow:

STEP 1: Start Metasploit Console

msfconsole

4)Risk Assessment Basics:

Risk Assessment = Identifying + Analyzing + Evaluating risks
to prioritize security efforts effectively

Formula:
RISK = THREAT × VULNERABILITY × IMPACT

Goal:
- Know what to fix first
- Allocate resources wisely
- Reduce overall risk exposure
- Meet compliance requirements

CVSS — Common Vulnerability Scoring System:

CVSS = Standard for rating severity of vulnerabilities
Body = FIRST (Forum of Incident Response & Security Teams)
Use = Helps prioritize which vulnerabilities to fix first

0.0 → No risk

0.1 - 3.9 → Low

4.0 - 6.9 → Medium

7.0 - 8.9 → High

9.0 - 10.0→ Critical

CVSS Score Calculation Examples:

VULNERABILITY: SQL Injection on public login page

Base Metrics:

Attack Vector : Network (N)

Attack Complexity : Low (L)

Privileges Required : None (N)

User Interaction : None (N)

Scope : Changed (C)

Confidentiality : High (H)

Integrity : High (H)

Availability : High (H)

CVSS Vector: AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

BASE SCORE : 10.0 (Critical) → Fix IMMEDIATELY

Risk Assessment Process:

Step-by-Step Methodology:

STEP 1: ASSET IDENTIFICATION

→ List all assets (servers, apps, data, people)

→ Assign value/criticality to each

STEP 2: THREAT IDENTIFICATION

→ What threats exist? (hackers, insiders, disasters)

→ Use threat libraries (STRIDE, MITRE ATT&CK)

STEP 3: VULNERABILITY IDENTIFICATION

→ Run scans (Nmap, OpenVAS, ZAP)

→ Review CVE databases

→ Manual testing

STEP 4: RISK ANALYSIS

→ Calculate: Likelihood × Impact

→ Use CVSS scores as input

→ Plot on Risk Matrix

STEP 5: RISK EVALUATION

→ Prioritize risks

→ Compare against risk tolerance

→ Determine acceptable vs unacceptable risks

STEP 6: RISK TREATMENT

→ Choose treatment strategy

→ Assign owners and deadlines

→ Implement controls

STEP 7: MONITOR & REVIEW

→ Track remediation progress

→ Reassess periodically

→ Update risk register

Risk Score Calculation:

Likelihood Scale:	Impact Scale:
1 = Rare	1 = Negligible

2 = Unlikely 2 = Minor

3 = Possible 3 = Moderate

4 = Likely 4 = Major

5 = Almost Certain 5 = Critical

Risk Score = Likelihood × Impact

1–4 → Very Low

5–9 → Low

10–14 → Medium

15–19 → High

20–25 → Critical

5) Common Vulnerabilities:

Vulnerability = Weakness that can be exploited by a threat

3 Key Elements:

FLAW → The actual weakness in system/code

EXPLOIT → Method used to take advantage of flaw

IMPACT → Damage caused if exploited

Goal of Learning:

Understand HOW vulnerabilities work

→ So you can DEFEND against them effectively

Network Vulnerabilities:

What Are Network Misconfigurations?

Most common cause of security breaches

Often result of:

- Human error
- Default settings not changed
- Poor security practices
- Lack of hardening procedures

Open Ports & Services:

Port = Communication endpoint (0–65535)

Categories:
0 – 1023 → Well-known ports (system services)
1024 – 49151 → Registered ports (applications)
49152– 65535 → Dynamic/private ports

Nmap NSE Scripts (Nmap Scripting Engine)

Categories:
auth → Authentication related
brute → Brute force attacks
default → Run with -sC flag
discovery→ Network discovery
exploit → Exploit vulnerabilities
vuln → Vulnerability detection
safe → Non-intrusive scripts
malware → Malware detection

Web Vulnerabilities:

SQL Injection = Inserting malicious SQL code into input fields to manipulate the database query

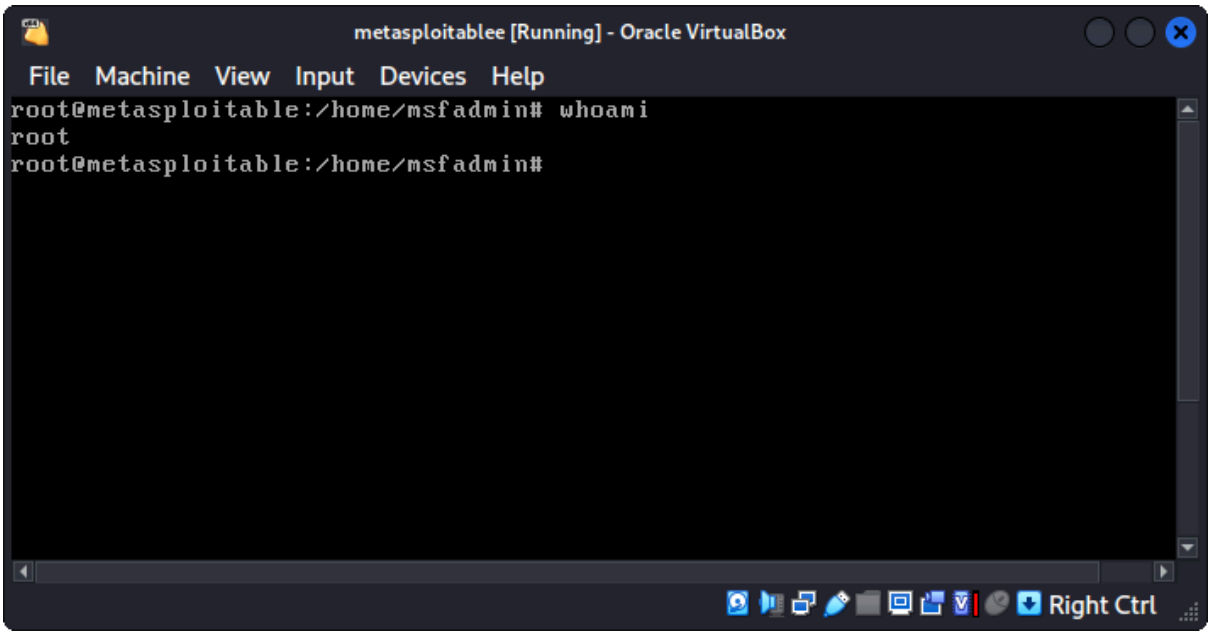
Root Cause: Unsanitized user input directly concatenated into SQL queries

What is XSS?

XSS = Injecting malicious scripts into web pages viewed by other users

What is Metasploitable?

Purpose : Intentionally vulnerable Linux VM
for penetration testing practice
Made by : Rapid7 (Metasploit creators)
Version : Metasploitable 2 (most common)
Metasploitable 3 (Windows/Linux)
Cost : Free



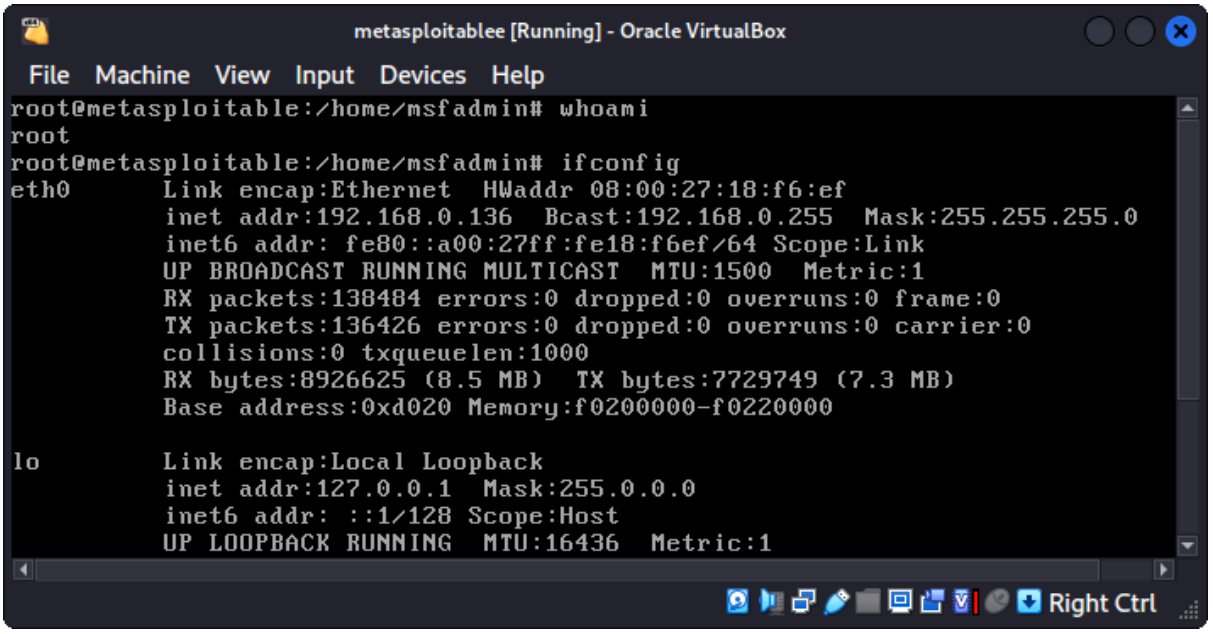
Setting Up Metasploitable 2:

STEP 1: Download
→ sourceforge.net/projects/metasploitable

STEP 2: Import to VirtualBox/VMware
→ File → Import Appliance → Select .vmx file

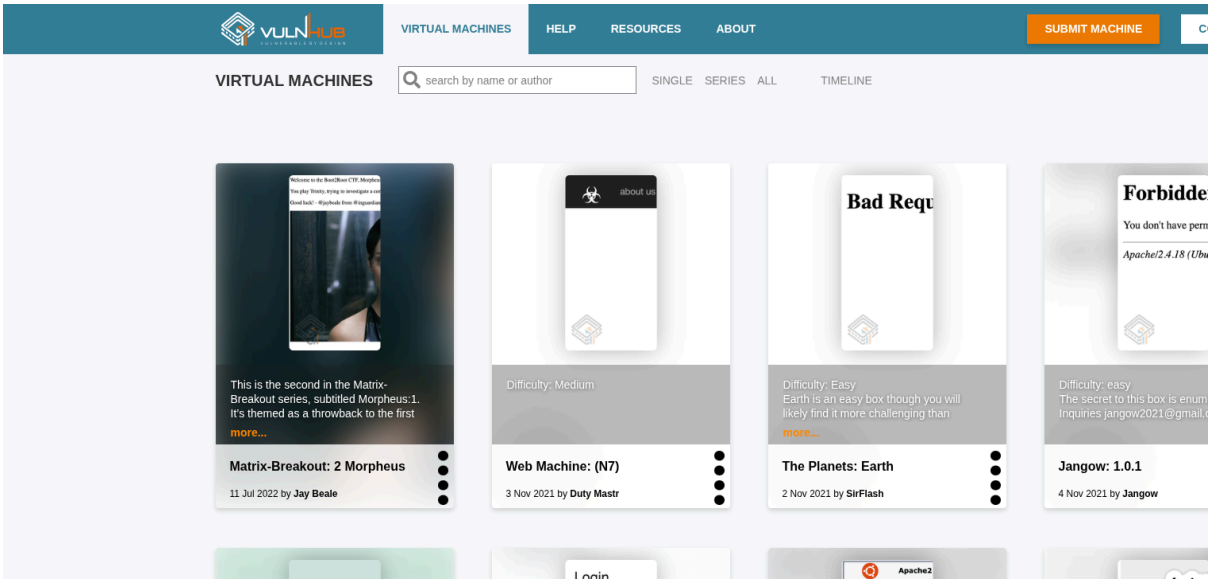
STEP 3: Network Configuration
→ Set BOTH VMs to "Host-Only" adapter
→ Kali Linux (Attacker) + Metasploitable (Target)
→ They can communicate, isolated from internet

STEP 4: Find Metasploitable IP
→ Login: msfadmin/msfadmin
→ Run: ifconfig



What is VulnHub?:

Platform : Collection of vulnerable VMs for practice and learning
URL : vulnhub.com
Cost : Free
Format : Download VM, import, practice



VulnHub Categories:

BEGINNER MACHINES:

- Kioptrix Level 1 → Classic Linux exploitation
- Mr-Robot → Based on TV show
- Basic Pentesting → Simple methodology practice
- Tr0ll → CTF style challenges

INTERMEDIATE MACHINES:
- DC Series → Multiple DC machines
- Bulldog → Web app + privilege escalation
- SickOs → Proxy and web exploitation

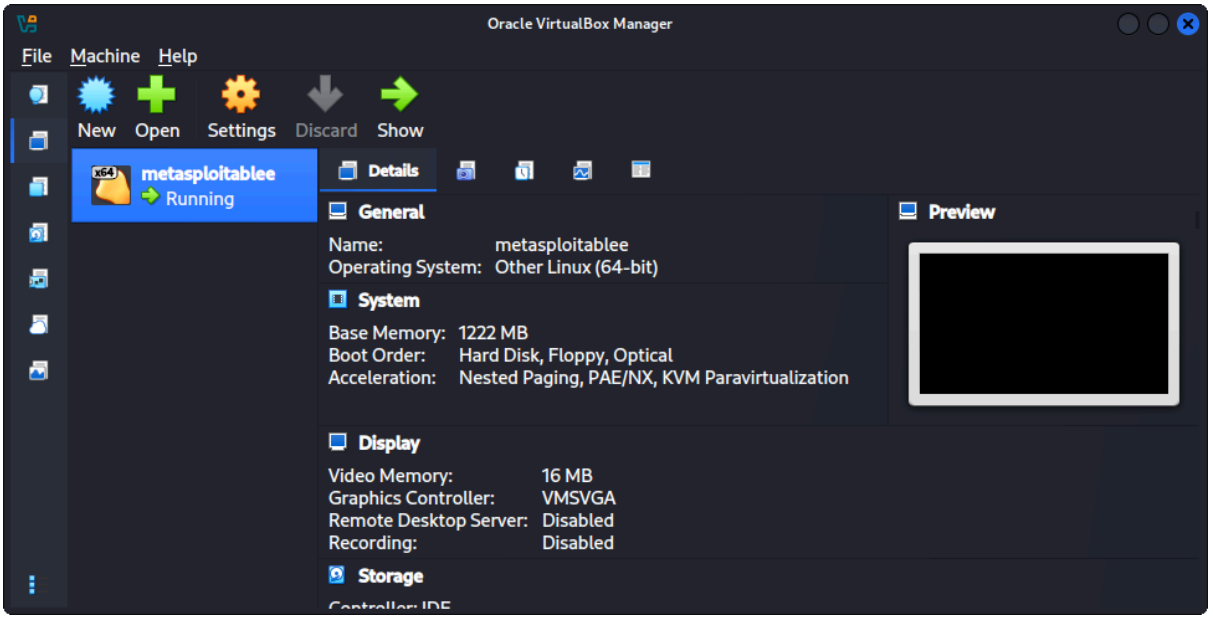
ADVANCED MACHINES:
- Brainpan → Buffer overflow focus
- Raven → Multiple attack vectors
- Symfonos Series → Linux privilege escalation

Setting Testing Environment:

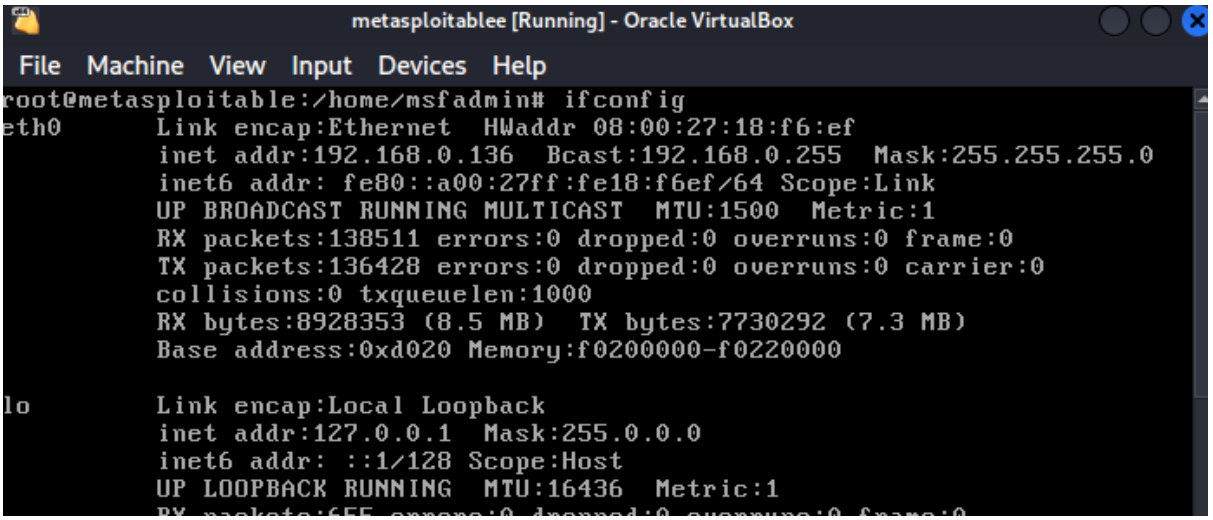
Openvas in installed in kali linux:

```
┌──(kali㉿localhost)-[~]
└─$ openvas --version
OpenVAS 23.41.6
gvm-libs 22.38.0
Most new code since 2005: (C) 2024 Greenbone AG
Nessus origin: (C) 2004 Renaud Deraison <deraison@nessus.org>
License GPLv2: GNU GPL version 2
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
```

Installing metasploitable vulnerable machine in Oracle virtual box and setting Network to Bridge mode:

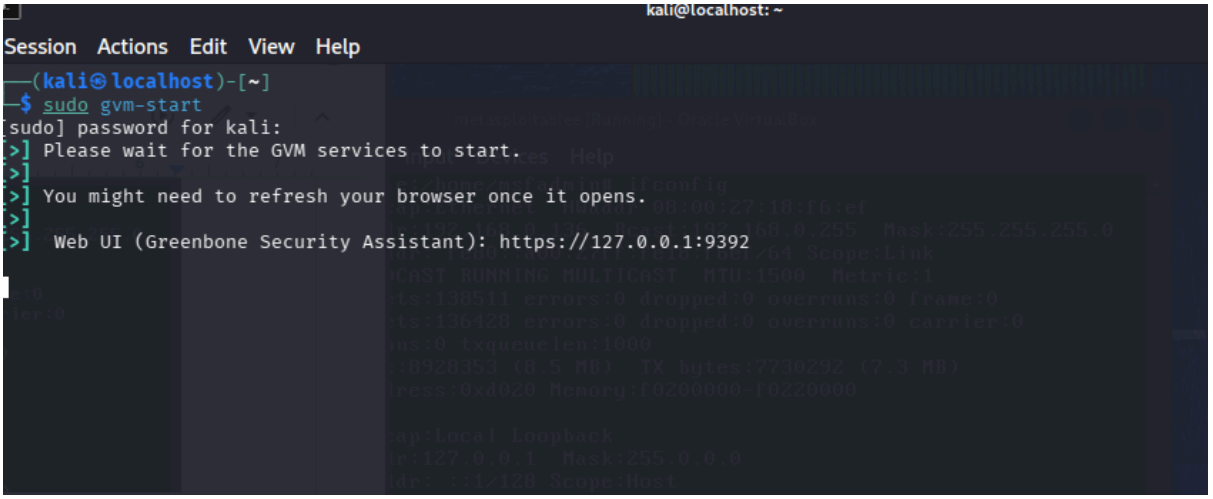


Setting metasploitable

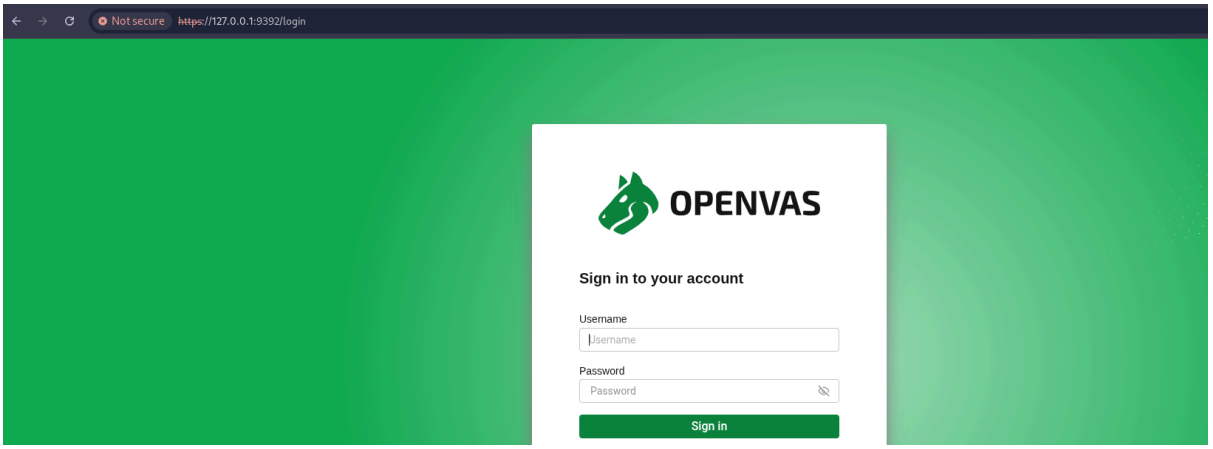


Now scanning This metasploitble os using openvas:

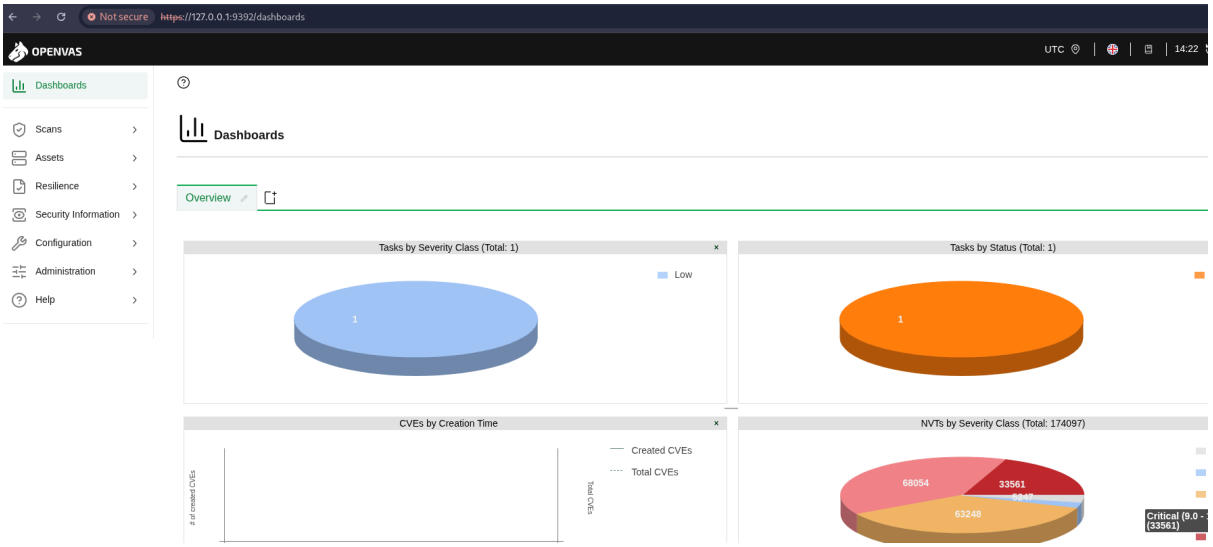
Sudo gvm-start



Opens the web interface

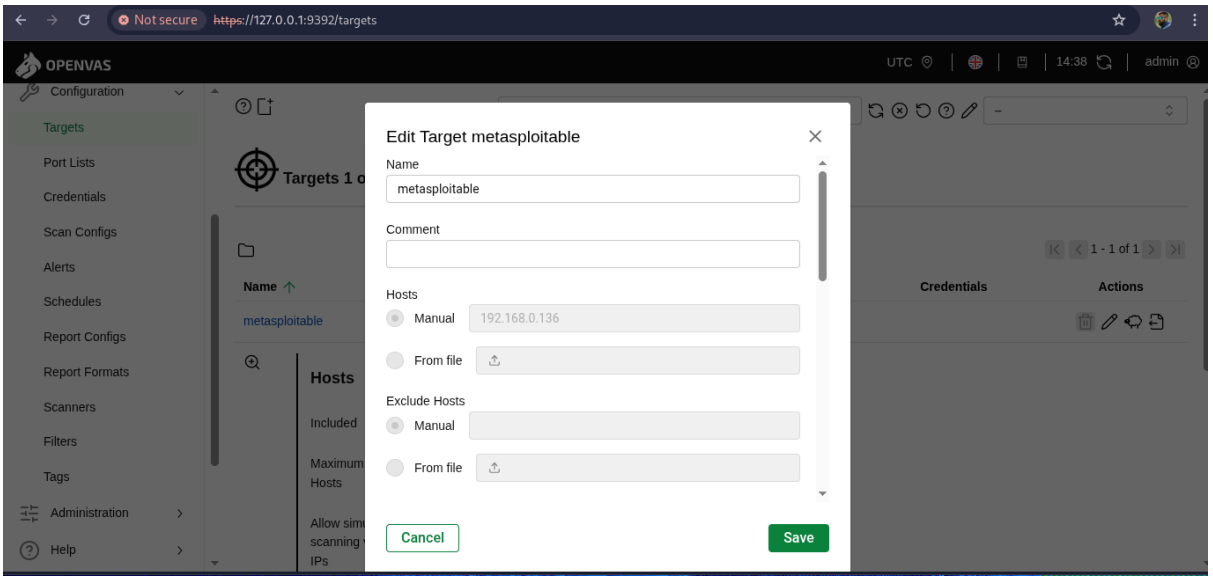


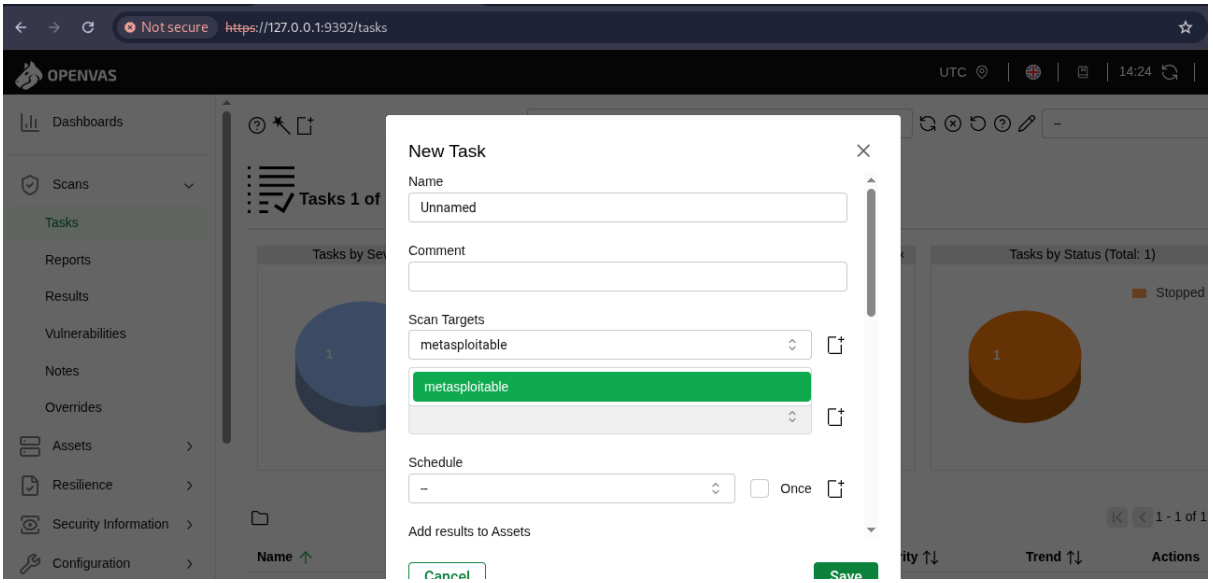
Entering credentials

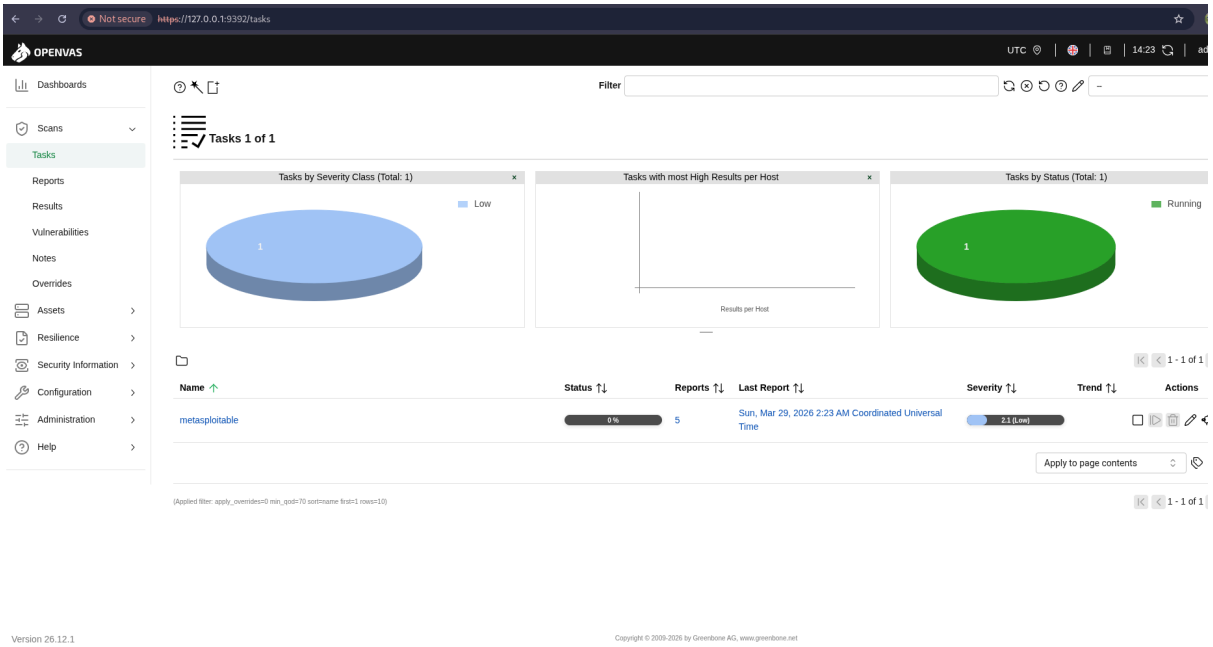


Creating Target using the metasploitable IP 192.168.0.136

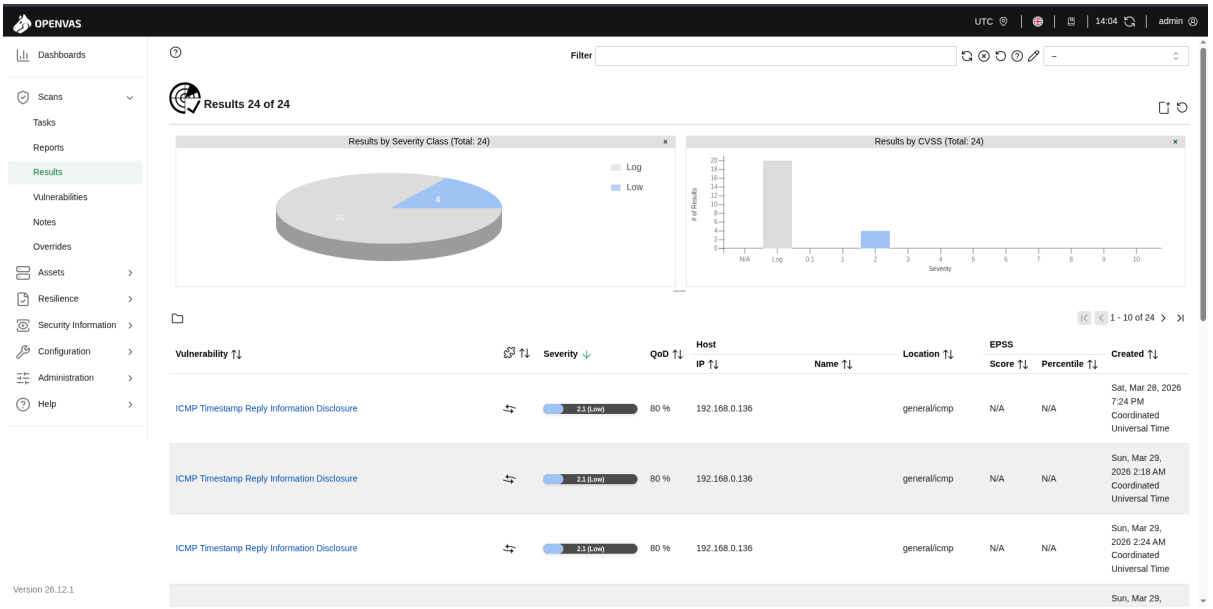
Creating Task and start scanning (waiting till the sync feed is completed)



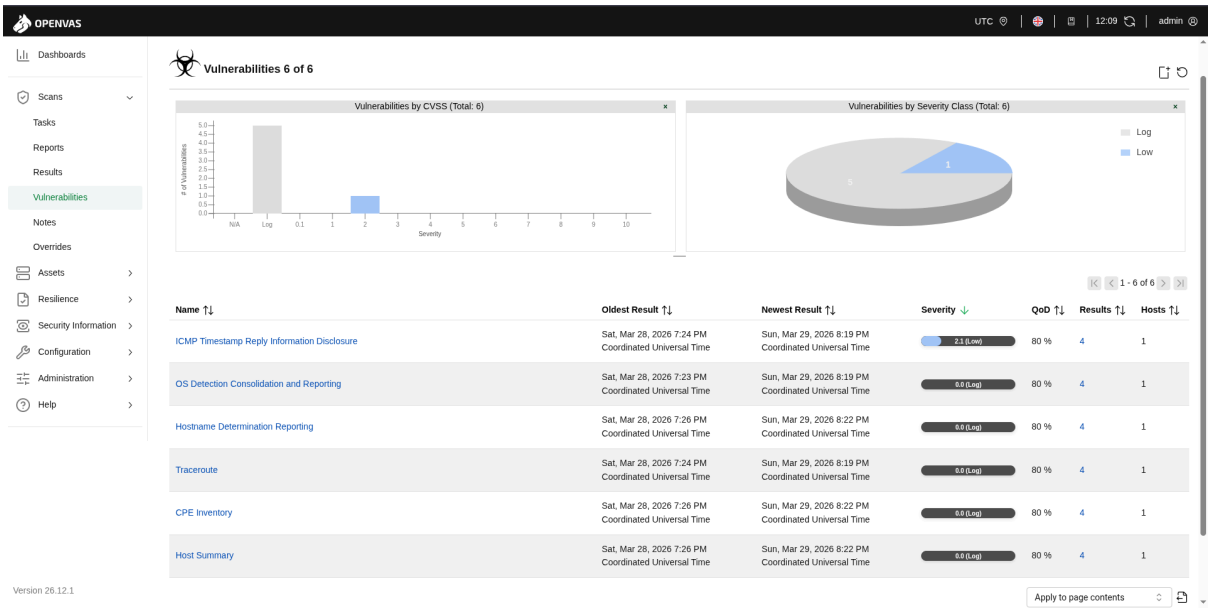


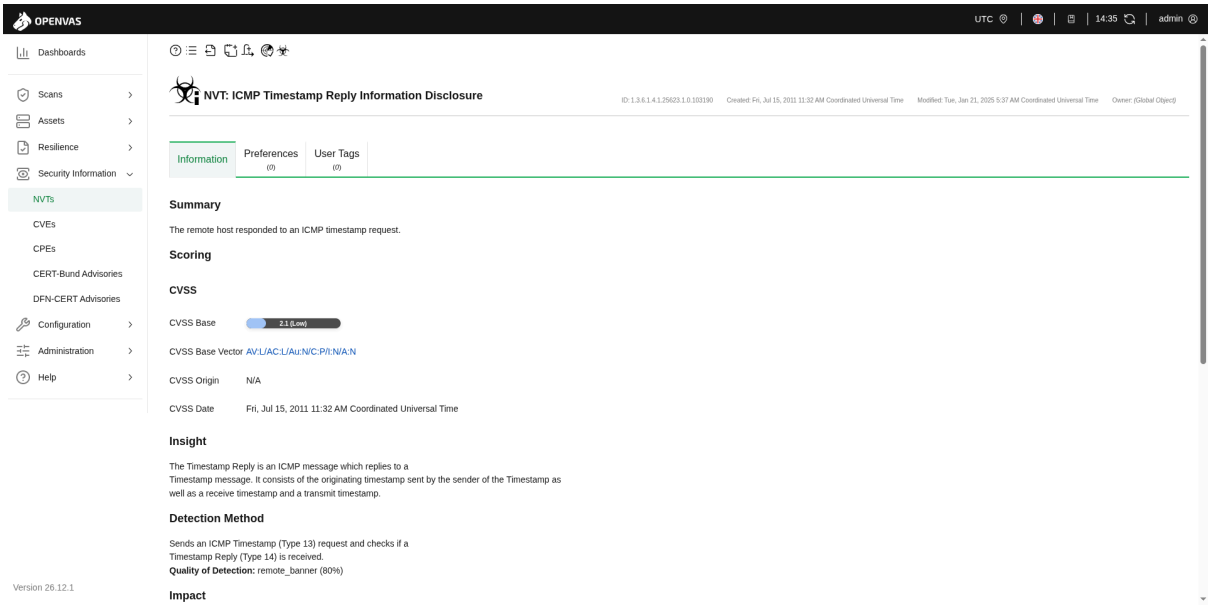


Analysing the results :



Vulnerabilities:




OPENVAS
UTC
14:35
admin
Dashboards
Scans
Assets
Resilience
Security Information
NVTs
CVEs
CPEs
CERT-Bund Advisories
DFN-CERT Advisories
Configuration
Administration
Help
Version 26.12.1
NVT: ICMP Timestamp Reply Information Disclosure
ID: 1.3.6.1.4.1.25623.1.0.103190
Created: Fri, Jul 15, 2011 11:32 AM Coordinated Universal Time
Modified: Tue, Jan 21, 2025 5:37 AM Coordinated Universal Time
Owner: (Global Object)
Information
Preferences
(0)
User Tags
(0)
Summary
The remote host responded to an ICMP timestamp request.
Scoring
CVSS
CVSS Base
2.1 (Low)
CVSS Base Vector AV:L/AC:L/Au:N/C:P/I:N/A:N
CVSS Origin N/A
CVSS Date Fri, Jul 15, 2011 11:32 AM Coordinated Universal Time
Insight
The Timestamp Reply is an ICMP message which replies to a
Timestamp message. It consists of the originating timestamp sent by the sender of the Timestamp as
well as a receive timestamp and a transmit timestamp.
Detection Method
Sends an ICMP Timestamp (Type 13) request and checks if a
Timestamp Reply (Type 14) is received.
Quality of Detection: remote_banner (80%)
Impact